# Il Regolamento Generale sulla Protezione dei Dati (GDPR)

## 1. Contesto storico e sociale

### Cosa è la privacy ed evoluzione nel tempo

Il concetto di privacy ha subito una profonda trasformazione nel corso degli ultimi decenni, passando da un'accezione statica a una dinamica. Originariamente, alla fine dell'Ottocento, la privacy era definita come *the right to be let alone* (il diritto di essere lasciati soli), intesa come la protezione della propria sfera privata da intrusioni esterne. In questa fase storica, la privacy riguardava principalmente l'inviolabilità del domicilio e della corrispondenza cartacea.

Oggi, nell'era digitale e dei Big Data, la privacy è intesa come **autodeterminazione informativa**: il diritto di ciascun individuo di esercitare un controllo attivo sui propri dati personali, decidendo chi può utilizzarli, per quali scopi e per quanto tempo. Non è più solo un "nascondere" informazioni, ma un "governare" il flusso delle informazioni che ci riguardano. In un mondo in cui ogni nostra azione online lascia una traccia (impronta digitale), la privacy è diventata un prerequisito per l'esercizio della libertà individuale.

### Rischi e pericoli

La massiccia raccolta di dati personali da parte di aziende (Data Broker, Social Network, Cloud Provider) e governi comporta rischi significativi:

- **Profilazione estrema:** La creazione di profili psicologici e comportamentali così precisi da poter prevedere (e influenzare) le decisioni d'acquisto, gli orientamenti politici o lo stato di salute degli individui.
- **Furto d'identità:** L'uso illecito dei dati personali per compiere frodi finanziarie o accedere a servizi a nome della vittima.
- **Discriminazione automatizzata:** L'utilizzo di algoritmi di intelligenza artificiale che, basandosi su dati storici distorti, possono discriminare l'accesso a prestiti, posti di lavoro o assicurazioni sulla base di origine etica, genere o stato di salute.
- **Perdita della reputazione:** La persistenza di informazioni obsolete o decontestualizzate online che possono danneggiare la vita professionale e privata di una persona (problema legato al diritto all'oblio).

### Concetto di privacy vs concetto di sicurezza

Spesso i due termini vengono confusi, ma nell'informatica giuridica mantengono una distinzione fondamentale. Per comprenderla meglio, è necessario introdurre il concetto cardine della sicurezza informatica: la **triade CIA** (o **RID** in italiano).

#### La Triade RID (Riservatezza, Integrità, Disponibilità)

Ogni sistema sicuro deve garantire tre pilastri fondamentali:

1. **Riservatezza (Confidentiality):** garantire che i dati siano accessibili solo a chi ne ha effettivamente il diritto (es. tramite cifratura e controllo accessi).
2. **Integrità (Integrity):** garantire che i dati non vengano modificati o cancellati da soggetti non autorizzati o da errori di sistema, rimanendo coerenti e affidabili.

3. **Disponibilità (Availability):** garantire che i dati e i servizi siano accessibili agli utenti autorizzati nel momento in cui ne hanno bisogno (es. protezione da attacchi DDoS o guasti hardware).

**La relazione di dipendenza**

Il rapporto tra privacy e sicurezza non è simmetrico:

- **Non può esistere privacy senza sicurezza:** se un sistema non è sicuro (es. subisce un accesso abusivo), la riservatezza dei dati personali viene meno e la privacy dell'individuo è violata. La sicurezza è dunque la condizione tecnica necessaria per l'esercizio del diritto alla privacy.
- **Può esistere sicurezza senza privacy:** un sistema può essere tecnicamente inattaccabile e garantire perfettamente la triade RID, ma essere al contempo uno strumento di violazione della privacy. Ad esempio, un software di sorveglianza di massa estremamente sicuro protegge i dati raccolti da hacker esterni (sicurezza), ma viola il diritto degli individui a non essere monitorati costantemente (privacy).

In sintesi: la sicurezza è lo strumento tecnico (il firewall, la cifratura), mentre la privacy è il diritto garantito all'individuo sull'uso che viene fatto di quegli strumenti.

### Evoluzione delle normative legate alla privacy

**In Europa**

L'Unione Europea è da sempre all'avanguardia nella protezione dei dati.

- **Direttiva 95/46/CE:** È stata la prima norma organica a livello europeo. Creata in un'epoca in cui internet era ancora agli albori, ha mostrato i suoi limiti con l'avvento dei social network e del cloud. Essendo una direttiva, richiedeva leggi di recepimento nazionali, portando a una frammentazione normativa tra i vari stati.
- **GDPR (Regolamento UE 2016/679):** È il pilastro attuale. Entrato in vigore nel 2016 e divenuto pienamente applicativo il **25 maggio 2018**. Essendo un "Regolamento", è immediatamente e direttamente applicabile in tutti gli Stati membri, garantendo un livello di protezione uniforme in tutta l'UE.

**In Italia**

- **Legge 675/1996:** La prima legge italiana sulla privacy, nata per recepire gli accordi europei.
- **D.Lgs 196/2003 ("Codice Privacy"):** Ha riordinato tutta la materia in un unico testo.
- **D.Lgs 101/2018:** Ha aggiornato e armonizzato il Codice Privacy italiano con le nuove disposizioni del GDPR europeo.

### Oggetto e finalità (Art. 1)

L'articolo 1 del GDPR chiarisce che il regolamento ha due scopi fondamentali e complementari:

1. **Proteggere i diritti e le libertà fondamentali delle persone fisiche**, in particolare il diritto alla protezione dei dati personali. Il dato personale è considerato un'estensione della dignità della persona.
2. **Garantire la libera circolazione dei dati personali** all'interno dell'Unione. Il GDPR non serve a "bloccare" i dati, ma a creare un clima di fiducia che ne permetta lo scambio sicuro per fini economici, scientifici o amministrativi.

## 2. Ambiti di applicazione

Per determinare se un'attività di trattamento dati debba rispettare le regole del GDPR, è necessario analizzare due ambiti: quello materiale (cosa viene trattato) e quello territoriale (dove e verso chi).

### Ambito di applicazione materiale (Art. 2)

Il GDPR si applica al trattamento di dati personali effettuato:

- **Interamente o parzialmente con mezzi automatizzati:** database, file di log, software gestionali, fogli di calcolo, algoritmi di IA.
- **Non automatizzato (cartaceo):** solo se i dati sono contenuti in un **archivio** o sono destinati a figurarvi. Un archivio è definito come qualsiasi insieme strutturato di dati personali accessibili secondo criteri determinati (es. uno schedario ordinato alfabeticamente).

**Casi di esclusione:** Il regolamento **non** si applica ai trattamenti:

- Effettuati per attività che non rientrano nell'ambito del diritto dell'Unione (es. sicurezza nazionale).
- Effettuati dalle autorità competenti per fini di prevenzione, indagine o perseguimento di reati (per questi esiste una direttiva specifica).
- **Trattamenti domestici:** effettuati da una persona fisica per l'esercizio di attività a carattere esclusivamente personale o domestico (es. la rubrica del telefono, i messaggi privati, le foto delle vacanze salvate sul PC). Attenzione: se tali dati vengono pubblicati online in modo accessibile a chiunque, il trattamento potrebbe uscire dall'ambito domestico.

### Ambito di applicazione territoriale (Art. 3)

Il GDPR ha una portata rivoluzionaria perché non si limita ai confini geografici dell'Europa. Si applica infatti:

1. **Criterio dello stabilimento:** Se il titolare o il responsabile del trattamento ha una sede (stabilimento) nell'Unione Europea, il regolamento si applica a prescindere dal fatto che il trattamento avvenga in Europa o altrove.
2. **Criterio del targeting (extraterritorialità):** Se il titolare o il responsabile **non** ha sedi nell'Unione, il GDPR si applica comunque se il trattamento riguarda persone (interessati) che si trovano nell'Unione e le attività riguardano:

- **L'offerta di beni o servizi:** a tali persone, indipendentemente dal fatto che sia richiesto un pagamento (es. un e-commerce americano che spedisce in Italia o un'app gratuita che offre servizi ai francesi).
- **Il monitoraggio del comportamento:** se tale comportamento ha luogo all'interno dell'Unione (es. l'uso di cookie di profilazione da parte di un sito straniero per tracciare le abitudini di navigazione di un cittadino europeo).

Questo principio garantisce che i cittadini europei siano protetti anche quando utilizzano servizi offerti da colossi tecnologici stranieri (es. Google, Meta, Amazon).

## 3. Definizioni (Art. 4)

Per comprendere il funzionamento del GDPR è indispensabile padroneggiare il lessico specifico utilizzato dal legislatore europeo.

### Il concetto di "Dato"

Il regolamento distingue diverse tipologie di dati in base alla loro natura e al rischio che il loro trattamento comporta per l'interessato.

**Dato Personale (Art. 4, punto 1)**

È **qualsiasi informazione** riguardante una persona fisica identificata o **identificabile**. Una persona si considera identificabile se può essere riconosciuta, direttamente o indirettamente, tramite uno o più elementi identificativi:

- **Identificativi diretti:** nome, cognome, codice fiscale.
- **Identificativi indiretti:** numero di telefono, targa dell'auto, indirizzo email.
- **Identificativi online:** indirizzo IP, cookie ID, User Agent del browser, identificativi univoci dei dispositivi (MAC address, IMEI), tag RFID.
- **Dati di ubicazione:** coordinate GPS, celle telefoniche.
- **Identità specifica:** elementi fisici, fisiologici, genetici, psichici, economici, culturali o sociali.

In ambito informatico, è fondamentale capire che anche un dato apparentemente anonimo (come un ID numerico in un database) è un dato personale se, incrociandolo con altre tabelle, è possibile risalire all'identità della persona.

**Categorie particolari di dati (ex "Sensibili") (Art. 9)**

Sono dati che meritano una protezione rafforzata perché la loro diffusione può dar luogo a gravi discriminazioni o violazioni della dignità. Il GDPR ne **vieta il trattamento in linea di principio**, salvo eccezioni specifiche (es. consenso esplicito, motivi di interesse pubblico rilevante, finalità di medicina del lavoro). Includono dati che rivelano:

- Origine razziale o etnica.
- Opinioni politiche, convinzioni religiose o filosofiche.
- Appartenenza sindacale.
- **Dati genetici e biometrici:** se trattati per identificare univocamente una persona fisica (es. FaceID, impronta digitale per accesso a sistemi).
- Dati relativi alla **salute** (cartelle cliniche, referti, stato di malattia).
- Dati relativi alla vita sessuale o all'orientamento sessuale.

**Dati Giudiziari (Art. 10)**

Sono dati relativi alle condanne penali, ai reati o a connesse misure di sicurezza. Il loro trattamento è consentito solo sotto il controllo dell'autorità pubblica o se autorizzato da norme specifiche che prevedano garanzie appropriate.

## Il Trattamento (Art. 4, punto 2)

La definizione di trattamento è onnicomprensiva. È "trattamento" **qualsiasi operazione** compiuta su dati personali, con o senza processi automatizzati. Include:

- Raccolta e registrazione.
- Organizzazione e strutturazione.
- Conservazione (anche il solo backup su server).
- Modifica o adattamento.
- Estrazione e consultazione (anche la sola visualizzazione a video da parte di un operatore).
- Uso e comunicazione mediante trasmissione o diffusione.
- Raffronto o interconnessione (es. join tra tabelle di database diversi).
- Limitazione, cancellazione o distruzione.

## Pseudonimizzazione vs Anonimizzazione

Dal punto di vista tecnico e informatico, è fondamentale distinguere queste due procedure, poiché determinano se il GDPR debba essere applicato o meno.

| Tecnica | Definizione | Esempio Pratico | Status Giuridico |
|---|---|---|---|
| **Dato in chiaro** | Informazione direttamente riconducibile all'interessato senza alcuno sforzo. | Nome: *Mario Rossi*<br>Email: *mario.rossi@email.it* | **Dato Personale** (Soggetto al GDPR) |
| **Pseudonimizzazione** | Sostituzione di identificativi con "pseudonimi". L'identificazione è possibile solo incrociando il dato con una chiave separata. | ID Utente: *8db4-f21e*<br>*(La tabella che associa l'ID a Mario Rossi è conservata separatamente e cifrata)* | **Dato Personale** (Soggetto al GDPR) |
| **Anonimizzazione** | Rimozione definitiva di ogni legame tra dato e persona. Non è possibile risalire all'identità nemmeno con informazioni aggiuntive. | Statistica: *"Il 15% degli utenti residenti a Milano usa Gmail"*<br>*(Non c'è modo di sapere chi siano i singoli utenti)* | **Dato Anonimo** (NON soggetto al GDPR) |

In informatica, la pseudonimizzazione è considerata una misura di sicurezza (Art. 32), mentre l'anonimizzazione è una strategia di uscita dall'ambito di applicazione del regolamento.

## 4. Principi (Art. 5)

L'articolo 5 definisce i principi cardine a cui ogni attività di trattamento deve ispirarsi. La violazione di questi principi comporta le sanzioni più elevate previste dal regolamento.

### 1. Liceità, correttezza e trasparenza

Il primo principio aggrega tre concetti distinti che regolano il rapporto tra il titolare del trattamento e l'interessato.

#### Liceità

Il trattamento deve fondarsi su una **base giuridica** valida. Non è consentito trattare dati in modo arbitrario o senza una giustificazione legale. È necessario che sussista una delle condizioni di liceità previste dall'Art. 6 del GDPR (ad esempio il consenso dell'interessato, l'esecuzione di un contratto, l'adempimento di un obbligo legale). In assenza di una base giuridica idonea, il trattamento è intrinsecamente illecito.

#### Correttezza

Il principio di correttezza impone di agire con lealtà e onestà nei confronti dell'interessato. I dati non devono essere utilizzati con modalità impreviste o che possano recare pregiudizio ingiustificato alla persona.

#### Focus: i dark patterns

Il termine **dark pattern** (o "modello manipolatorio") identifica interfacce e percorsi utente progettati per influenzare, ingannare o manipolare le persone affinché compiano scelte che non avrebbero altrimenti fatto, spesso a scapito della loro privacy o dei loro interessi economici.

Il concetto è stato coniato nel 2010 da Harry Brignull (esperto di UX design) e ha assunto una rilevanza centrale con l'entrata in vigore del GDPR, poiché queste pratiche violano direttamente il principio di **correttezza** e rendono spesso invalido il **consenso** dell'utente.

#### PERCHÉ SONO ILLEGALI?

Secondo le linee guida dell'EDPB (European Data Protection Board), i dark patterns contrastano con diversi pilastri del GDPR:

- **Violazione della Correttezza**: il titolare del trattamento non agisce lealmente, ma usa la psicologia comportamentale per "estorcere" dati.
- **Invalidità del Consenso**: l'Art. 7 richiede che il consenso sia libero, specifico e informato. Un'interfaccia manipolatoria nega la libertà di scelta.
- **Privacy by Design**: i sistemi dovrebbero essere progettati per proteggere l'utente, non per sfruttarne i bias cognitivi.

#### TASSONOMIA DEI DARK PATTERNS (EDPB)

L'autorità europea ha classificato queste tecniche in diverse categorie principali:

1. **Overloading (Sovraccarico)**: somministrare all'utente una mole eccessiva di informazioni o opzioni per indurlo a condividere dati per stanchezza (es. cookie banner con centinaia di interruttori da gestire manualmente).
2. **Skipping (Salto)**: progettare l'interfaccia in modo che l'utente ignori o dimentichi le impostazioni sulla privacy (es. posizionare le opzioni critiche in fondo a pagine lunghissime).
3. **Stirring (Emozione)**: utilizzare elementi visivi o linguaggio emotivo per influenzare la scelta (es. usare colori vivaci per "Accetta tutto" e grigio spento per "Rifiuta", o usare icone di pericolo vicino alle opzioni di protezione).
4. **Hindering (Ostacolo)**: rendere estremamente difficile o frustrante compiere un'azione a tutela della privacy (es. il già citato *roach motel*).
5. **Fickle (Instabile)**: modificare l'interfaccia in modo incoerente, rendendo difficile per l'utente mantenere il controllo (es. cambiare la posizione dei pulsanti di negazione tra una pagina e l'altra).
6. **Left in the dark (Al buio)**: nascondere informazioni fondamentali o fornire spiegazioni ambigue sul trattamento dei dati.

#### CASI STUDIO EMBLEMATICI

- **Amazon (Progetto Iliad)**: l'azienda è stata accusata di aver reso deliberatamente complesso il processo di cancellazione dell'abbonamento Amazon Prime. Il percorso richiedeva molteplici passaggi (pagine multiple, domande fuorvianti, pulsanti con diciture ambigue come "Keep my benefits") progettati per indurre l'utente a desistere. Questo modello è stato soprannominato "Iliad" proprio per richiamare la lunghezza e la difficoltà di un poema epico.
- **Ryanair (Dark patterns a cascata)**: il sito della compagnia aerea è stato spesso citato per l'uso massiccio di tecniche manipolatorie durante il processo di acquisto:
  - Assicurazione di viaggio inserita come opzione predefinita o nascosta in menu a tendina tra i nomi dei paesi.
  - Pulsanti "Continua" che portano all'acquisto di servizi extra non richiesti.
  - Countdown temporali ("Prenota entro 5 minuti!") per generare ansia e ridurre il tempo di riflessione sulla privacy e sui costi.
- **Confirmshaming (L'umiliazione dell'utente)**: si verifica quando il rifiuto di un servizio viene accompagnato da un messaggio colpevolizzante.

- *Esempio*: un popup che offre uno sconto in cambio dell'iscrizione alla newsletter con i due pulsanti: "Sì, voglio lo sconto" e "No, preferisco pagare il prezzo pieno" (oppure "No, odio le offerte").

**LA DIFESA CONTRO I DARK PATTERNS**

La consapevolezza è la prima difesa. Gli utenti (e i futuri sviluppatori) devono imparare a riconoscere queste trappole psicologiche:

- **Analisi critica del layout**: perché quel pulsante è più grande dell'altro?
- **Lettura delle etichette**: cosa significa davvero "Accetta i partner selezionati"?
- **Design Etico**: gli sviluppatori dovrebbero adottare pattern che rispettino l'autonomia dell'utente, garantendo che le azioni di protezione della privacy siano semplici quanto quelle di condivisione.

Il sito Hall of Shame raccoglie una vasta collezione di questi esempi per educare professionisti e utenti a un web più trasparente.

### Trasparenza

Ogni informazione riguardante il trattamento deve essere **facilmente accessibile** e **comprensibile**.

- **Linguaggio**: l'informativa deve utilizzare un linguaggio chiaro e semplice, evitando tecnicismi legali eccessivi, in particolare quando i servizi sono rivolti a minori.
- **Accessibilità**: le informazioni devono essere reperibili con facilità, evitando l'inserimento in percorsi di navigazione complessi.
- **Completezza**: l'interessato deve essere pienamente consapevole dell'identità del titolare, delle finalità del trattamento e del periodo di conservazione dei dati.

## 2. Limitazione della finalità

I dati devono essere raccolti per finalità **determinate, esplicite e legittime**. Questo principio impedisce l'uso indiscriminato delle informazioni e la sorveglianza di massa.

- **Determinate**: lo scopo del trattamento deve essere definito chiaramente prima dell'inizio della raccolta dati.
- **Esplicite**: le finalità devono essere dichiarate in modo inequivocabile nell'informativa.
- **Legittime**: gli scopi perseguiti devono essere conformi alla normativa vigente.

### Il divieto di "function creep"

I dati raccolti per una specifica finalità non possono essere successivamente trattati per scopi diversi e incompatibili senza una nuova base giuridica. Tale fenomeno è definito **function creep**.

> ***Esempio****: un'applicazione per l'utilizzo del flash dello smartphone richiede l'accesso alla fotocamera. Se l'applicazione utilizzasse la fotocamera per raccogliere dati biometrici o analizzare l'ambiente circostante a fini di marketing, violerebbe il principio di limitazione della finalità.*

> ***Esempio scolastico****: qualora un istituto scolastico raccolga gli indirizzi email degli studenti per comunicazioni didattiche, non è consentito cedere tali contatti a enti esterni per l'invio di materiale pubblicitario, in quanto finalità incompatibile con quella originaria.*

## 3. Minimizzazione dei dati

Il trattamento deve limitarsi ai dati **adeguati, pertinenti e necessari** rispetto alle finalità perseguite.

Questo principio richiede di abbandonare la logica della raccolta indiscriminata in favore della raccolta **strettamente indispensabile**.

- **Necessità**: qualora sia possibile raggiungere il medesimo risultato senza l'utilizzo di dati personali o riducendone la quantità, è obbligatorio procedere in tal senso.
- **Rischi dell'accumulo**: la conservazione di dati non necessari (data hoarding) comporta costi di gestione e incrementa i rischi di sicurezza. Maggiori sono i dati conservati, più gravi possono essere le conseguenze di una violazione (data breach).
- **Pertinenza**: la richiesta di informazioni non correlate al servizio offerto (es. dati sanitari per l'iscrizione a una newsletter automobilistica) viola il principio di pertinenza.

## 4. Esattezza

I dati devono essere **esatti** e, se necessario, **aggiornati**. Il titolare è tenuto ad adottare tutte le misure ragionevoli per cancellare o rettificare tempestivamente i dati inesatti.

- **Qualità del dato**: l'utilizzo di dati obsoleti o errati può causare pregiudizi all'interessato (es. mancata erogazione di un servizio per informazioni anagrafiche non aggiornate).
- **Dovere di verifica**: le organizzazioni non devono basare i propri processi su database non verificati o non aggiornati.
- **Rettifica**: a seguito di segnalazione da parte dell'interessato, il titolare ha l'obbligo di procedere alla rettifica immediata dei dati.

## 5. Limitazione della conservazione

I dati devono essere conservati in una forma che consenta l'identificazione degli interessati per un arco di tempo **non superiore al conseguimento delle finalità** per le quali sono stati trattati.

- **Durata del trattamento**: i dati non possono essere conservati a tempo indeterminato. È necessario stabilire criteri precisi per determinare i tempi di cancellazione.
- **Data retention policy**: le organizzazioni devono definire preventivamente i tempi di conservazione.
    - *Esempio*: i curriculum vitae ricevuti per una selezione non possono essere conservati indefinitamente, ma per un periodo limitato (solitamente 12-24 mesi), al termine del quale devono essere cancellati.
    - *Esempio*: i dati fiscali devono essere conservati per 10 anni in ottemperanza agli obblighi di legge, ma non oltre tale termine senza una valida giustificazione.
- **Cancellazione o anonimizzazione**: al termine del periodo di conservazione, i dati devono essere cancellati in modo sicuro o resi anonimi in via irreversibile.

## 6. Integrità e riservatezza

Il trattamento deve garantire un'adeguata sicurezza, compresa la protezione — mediante misure tecniche e organizzative — da trattamenti non autorizzati o illeciti e dalla perdita, distruzione o danno accidentali. Questo principio lega indissolubilmente la privacy alla **Cybersecurity** (CIA triad: Confidentiality, Integrity, Availability).

## 7. Responsabilizzazione (Accountability)

Il principio di accountability (Art. 5, par. 2) rappresenta un **cambio di paradigma** fondamentale introdotto dal GDPR.

Il **titolare del trattamento** è responsabile del rispetto dei principi e **deve essere in grado di comprovarlo**.

**Dall'approccio formale all'approccio sostanziale**

Non è più sufficiente un adempimento meramente formale o burocratico. È necessario dimostrare di aver adottato misure proattive ed efficaci per la protezione dei dati.

- **Inversione dell'onere della prova**: in sede di controllo, spetta al titolare dimostrare la conformità del proprio operato attraverso la documentazione prodotta.
- **Proattività**: l'approccio deve essere preventivo, basato sull'analisi dei rischi e sulla progettazione della privacy fin dalle fasi iniziali (privacy by design).
- **Documentazione**: la documentazione costituisce la prova essenziale dell'adempimento. Il registro dei trattamenti, le valutazioni d'impatto (DPIA) e le procedure di gestione dei data breach sono strumenti fondamentali di accountability.

# 5. Liceità e consenso (Art. 6, 7, 8)

Il principio di liceità stabilisce che ogni trattamento di dati personali deve fondarsi su una solida base giuridica. In assenza di una di queste giustificazioni, il trattamento è considerato illecito. Sebbene sovente si ritenga erroneamente che il consenso costituisca l'unica base possibile, il GDPR ne prevede sei, tutte di pari dignità gerarchica. Affinché il trattamento sia lecito, è necessario che sussista almeno una di queste condizioni. Non esiste una gerarchia predefinita; l'individuazione della base corretta dipende dalla relazione tra il Titolare e l'Interessato e dalla finalità del trattamento.

## Le basi giuridiche del trattamento (Art. 6)

### 1.1 Il consenso dell'interessato

Il trattamento è lecito qualora l'interessato abbia espresso il proprio consenso per una o più specifiche finalità. Rappresenta la base più comune nei servizi digitali opzionali, quali marketing, profilazione o programmi di fidelizzazione. Tuttavia, il consenso costituisce la base giuridica più instabile, in quanto può essere revocato in qualsiasi momento, imponendo al titolare l'immediata interruzione del trattamento.

- **Ambito di applicazione**: si utilizza quando l'utente dispone di un'effettiva facoltà di scelta e il trattamento non risulta essenziale per l'erogazione del servizio principale.

### 1.2 Esecuzione di un contratto

Il trattamento è lecito qualora sia necessario all'esecuzione di un contratto di cui l'interessato è parte o all'esecuzione di misure precontrattuali adottate su richiesta dello stesso.

- **Esempio contrattuale**: per finalizzare l'acquisto di un prodotto online, l'e-commerce necessita dell'indirizzo di spedizione. Tale trattamento non richiede un consenso specifico, in quanto il dato è indispensabile per l'esecuzione del contratto (consegna del bene).
- **Esempio precontrattuale**: qualora un utente richieda un preventivo aziendale, il trattamento dei suoi dati per la predisposizione dell'offerta è lecito. Non è necessario richiedere il consenso, trattandosi di una misura precontrattuale sollecitata dall'interessato.

### 1.3 Adempimento di un obbligo legale

Il trattamento è lecito se necessario per adempiere un obbligo legale al quale è soggetto il titolare del trattamento. In tale circostanza, la volontà delle parti non è determinante, in quanto il trattamento è imposto da una norma nazionale o europea.

- **Esempio fiscale**: l'emissione di una fattura elettronica impone l'acquisizione del codice fiscale o della partita IVA. L'esercente è obbligato per legge a raccogliere tali dati e l'utente non può opporsi.

- **Esempio previdenziale**: la comunicazione dei dati dei dipendenti all'INPS per finalità contributive.

#### 1.4 Salvaguardia degli interessi vitali

Il trattamento è lecito se necessario per la salvaguardia degli interessi vitali dell'interessato o di un'altra persona fisica. Questa base giuridica trova applicazione in situazioni di estrema emergenza, ove siano compromesse la vita o l'integrità fisica e l'interessato si trovi nell'impossibilità di prestare il consenso.

- **Esempio**: nel caso di un paziente giunto al pronto soccorso in stato di incoscienza a seguito di un incidente, i sanitari possono consultare la cartella clinica o ricercarne l'identità per prestare le cure necessarie.
- **Limiti**: non è applicabile per trattamenti sanitari ordinari o programmabili.

#### 1.5 Esecuzione di un compito di interesse pubblico

Il trattamento è lecito se necessario per l'esecuzione di un compito di interesse pubblico o connesso all'esercizio di pubblici poteri di cui è investito il titolare. È la base giuridica tipica della Pubblica Amministrazione, degli istituti scolastici pubblici, delle università o delle forze dell'ordine.

- **Esempio scolastico**: la gestione dei voti degli studenti nel registro elettronico da parte di una scuola pubblica avviene in virtù dei compiti istituzionali di istruzione.
- **Distinzione dall'obbligo legale**: mentre l'obbligo legale scaturisce da una norma specifica che impone una determinata azione, l'interesse pubblico deriva dal mandato generale conferito all'ente.

#### 1.6 Legittimo interesse

Il trattamento è lecito se necessario per il perseguimento del legittimo interesse del titolare o di terzi, a condizione che non prevalgano gli interessi o i diritti e le libertà fondamentali dell'interessato, in particolare se minore. Si tratta della base giuridica più flessibile ma che richiede una rigorosa valutazione preliminare (LIA - Legitimate Interest Assessment).

- **Test di bilanciamento**: il titolare è tenuto a valutare se il proprio interesse aziendale prevalga sul diritto alla riservatezza dell'utente.
- **Esempio sicurezza**: l'installazione di sistemi di videosorveglianza per la tutela del patrimonio aziendale.
- **Esempio marketing**: l'invio di comunicazioni commerciali relative a prodotti analoghi a quelli già acquistati (soft spam) a clienti esistenti.
- **Esempio antifrode**: le attività di prevenzione delle frodi nei pagamenti digitali.
- **Diritto di opposizione**: l'interessato ha facoltà di opporsi a tale trattamento (opt-out), obbligando il titolare all'interruzione dello stesso, salvo la dimostrazione di motivi legittimi cogenti.

## Il consenso (Art. 7)

Qualora il titolare opti per il consenso come base giuridica, deve garantire il rispetto dei rigorosi requisiti di validità definiti dagli articoli 4 e 7 del GDPR. Un consenso acquisito in violazione di tali norme è nullo e rende il trattamento illecito.

#### I quattro requisiti del consenso

Per essere considerato valido, il consenso deve possedere le seguenti caratteristiche:

- **Libero**: l'interessato non deve subire condizionamenti, pressioni o minacce. È necessario escludere qualsiasi evidente squilibrio di potere.

    - *Divieto di bundling*: è illegittimo subordinare l'erogazione di un servizio (es. download di un ebook) al consenso per finalità non necessarie (es. marketing di terze parti). Se l'accettazione è forzata per accedere al servizio, il consenso non si considera libero.
- **Specifico**: il consenso deve essere richiesto per finalità determinate (principio di granularità). Non sono ammessi consensi generici o cumulativi.
    - *Esempio*: per inviare newsletter, effettuare profilazione e cedere dati a terzi, è necessario predisporre tre distinte opzioni di scelta. Non è sufficiente un'unica accettazione della privacy policy.
- **Informato**: prima di prestare il consenso, l'utente deve aver preso visione dell'informativa privacy e averne compreso il contenuto. Fra consapevolezza è un prerequisito fondamentale.
- **Inequivocabile**: deve sussistere un'azione positiva e chiara da parte dell'interessato.
    - *Inammissibilità del silenzio-assenso*: il silenzio, l'inattività o le caselle pre-selezionate sono pratiche illegittime. L'utente deve compiere un'azione esplicita, come apporre una spunta o cliccare un pulsante.

**La gestione del consenso nel tempo**

Il consenso non rappresenta un atto statico, bensì una relazione dinamica che richiede una gestione continuativa.

- **Accountability**: il titolare ha l'onere di registrare e conservare la prova del consenso acquisito (identità del consenziente, data, versione dell'informativa).
- **Revoca (Opt-out)**: l'interessato ha il diritto di revocare il consenso in qualsiasi momento. La procedura di revoca deve essere semplice quanto quella di conferimento: se il consenso è stato prestato con un click, deve poter essere revocato con analoga immediatezza. Non è lecito richiedere procedure complesse (es. raccomandate o login articolati) per la disiscrizione.
- **Rinnovo del consenso**: qualora mutino le finalità del trattamento o trascorra un lasso di tempo significativo che renda il consenso obsoleto, è necessario richiederlo nuovamente.

**Il trattamento dei dati dei minori (Art. 8)**

Il GDPR riserva una tutela rafforzata ai minori, in quanto soggetti vulnerabili potenzialmente meno consapevoli dei rischi, delle conseguenze e dei propri diritti in materia di trattamento dei dati personali.

**Consenso digitale e soglie di età**

Relativamente all'offerta diretta di servizi della società dell'informazione (social network, applicazioni, giochi online, piattaforme di streaming) ai minori, la validità del consenso è subordinata al raggiungimento di una specifica età.

- **Soglia europea**: l'articolo 8 fissa l'età del consenso digitale a **16 anni**.
- **Deroga nazionale**: il GDPR consente agli Stati membri di abbassare tale soglia fino a un minimo di 13 anni.
- **Normativa italiana**: il D.Lgs 101/2018 ha stabilito la soglia a **14 anni**.
    - Un minore di 14 anni può iscriversi autonomamente a piattaforme social.
    - Un minore di 13 anni necessita dell'autorizzazione dei genitori.

**La responsabilità genitoriale e la verifica**

Al di sotto della soglia di età (14 anni in Italia), il trattamento è lecito esclusivamente se il consenso è prestato o autorizzato dal titolare della responsabilità genitoriale.

- **Verifica dell'età (Age Verification)**: il titolare del trattamento non può limitarsi ad accettare una mera dichiarazione dell'utente. Deve adottare ogni misura ragionevole, in considerazione

delle tecnologie disponibili, per verificare l'effettiva età dell'utente o l'avvenuta autorizzazione genitoriale.
    - Tale verifica presenta complessità tecniche, dovendo bilanciare l'accertamento dell'età con la minimizzazione dei dati raccolti. I metodi diffusi includono la verifica tramite strumenti di pagamento, sistemi di identità digitale (SPID) o stima dell'età tramite analisi biometriche (con le dovute cautele privacy).

#### Linguaggio adeguato al minore

Il principio di trasparenza (Art. 12) impone che qualsiasi informazione rivolta specificamente a un minore sia formulata con un linguaggio semplice, chiaro e comprensibile. È necessario evitare tecnicismi legali, privilegiando spiegazioni visuali o supporti multimediali esplicativi.

### Casi di esempio

La corretta individuazione della base giuridica richiede un'attenta analisi del contesto. L'errata applicazione della base giuridica rende il trattamento illecito.

- **Prenotazione volo aereo**: base giuridica **contratto**. I dati anagrafici e il documento di identità sono necessari per l'emissione del titolo di viaggio. Non è applicabile il consenso, poiché il rifiuto impedirebbe l'erogazione del servizio.
- **Marketing via SMS**: base giuridica **consenso** (libero e specifico). L'utente deve poter acquistare il prodotto o servizio indipendentemente dalla ricezione di comunicazioni promozionali.
- **Retribuzione dipendente**: basi giuridiche **obbligo legale** (adempimenti fiscali) e **contratto** (rapporto di lavoro).
- **Videosorveglianza in esercizio commerciale**: base giuridica **legittimo interesse** (tutela del patrimonio), bilanciato dall'assenza di riprese in aree riservate (camerini, servizi igienici) e dalla presenza di apposita segnaletica.
- **Ricerca medica su paziente incosciente**: base giuridica **interessi vitali**.
- **Geolocalizzazione veicoli aziendali**: può basarsi sul **legittimo interesse** (logistica, sicurezza) o sul **contratto**, nel rispetto della normativa sul lavoro (Statuto dei Lavoratori) e previa adeguata informativa ai conducenti.

## 6. Diritti degli interessati (Art. 12-22)

Il GDPR mette al centro l'individuo (l'interessato), dotandolo di una serie di strumenti per mantenere il controllo sulle proprie informazioni. Il titolare deve agevolare l'esercizio di questi diritti e rispondere alle richieste, di norma, entro un mese.

### Diritto all'informativa (Art. 13, 14)

L'informativa rappresenta la condizione essenziale affinché un trattamento sia trasparente e lecito, non limitandosi a un mero adempimento burocratico. In assenza di un'adeguata informativa, l'eventuale consenso raccolto risulta invalido.

#### Tempistiche di fornitura

Il momento in cui l'informativa deve essere resa disponibile dipende dalla modalità di ottenimento dei dati:

- **Raccolta diretta (presso l'interessato)**: l'informativa deve essere fornita contestualmente alla raccolta dei dati.
    - *Esempio*: nel caso di compilazione di un modulo di registrazione su un sito web,

l'informativa (o il collegamento ad essa) deve essere visibile prima dell'invio dei dati.

- **Raccolta indiretta (presso terzi)**: qualora i dati provengano da altre fonti (ad esempio tramite acquisto di database o fonti accessibili al pubblico), è necessario informare l'interessato entro un termine ragionevole, non superiore a **1 mese**, oppure al momento della prima comunicazione.

#### Contenuto obbligatorio

L'informativa deve fornire risposte chiare in merito ai soggetti coinvolti, alle finalità, alle modalità e ai tempi del trattamento. Gli elementi indispensabili includono:

- **Identità del titolare**: i dati identificativi del soggetto che effettua il trattamento e i contatti del DPO (se designato).
- **Finalità e base giuridica**: le motivazioni del trattamento (es. spedizione di un ordine) e il fondamento giuridico che lo legittima (es. esecuzione di un contratto).
- **Destinatari**: i soggetti a cui i dati potranno essere comunicati (es. corrieri, consulenti fiscali).
- **Trasferimenti extra-UE**: l'eventuale trasferimento dei dati al di fuori dell'Unione Europea e le relative garanzie di sicurezza.
- **Periodo di conservazione**: la durata della conservazione dei dati o i criteri utilizzati per determinarla.
- **Diritti dell'interessato**: l'elenco dei diritti esercitabili, inclusa la facoltà di revocare il consenso o proporre reclamo all'autorità di controllo.
- **Natura del conferimento**: l'indicazione se il conferimento dei dati sia obbligatorio o facoltativo e le conseguenze di un eventuale rifiuto (es. impossibilità di erogare il servizio).

#### Modalità di presentazione

Il GDPR impone che l'informativa sia:

- **Concisa, trasparente e facilmente accessibile**.
- Redatta con un **linguaggio semplice e chiaro**, in particolare se destinata ai minori.

Al fine di evitare testi eccessivamente lunghi e complessi, si raccomanda l'adozione di un approccio **a livelli (layered notice)**:

1. **Informativa breve**: un primo livello di immediata consultazione contenente le informazioni essenziali (titolare, finalità, diritti).

- *Esempio*: la segnaletica per la **videosorveglianza** approvata dal Garante costituisce un esempio di informativa breve, riportando esclusivamente il soggetto che effettua la registrazione, le finalità e le modalità di accesso all'informativa completa.

2. **Informativa estesa**: il documento completo consultabile tramite collegamento ipertestuale, codice QR o su richiesta specifica.

### Diritto di accesso (Art. 15)

Il diritto di accesso costituisce uno strumento fondamentale per consentire all'interessato di esercitare un controllo effettivo sui propri dati. La conoscenza di quali soggetti trattino i propri dati personali è infatti propedeutica all'esercizio degli altri diritti (rettifica, cancellazione, ecc.).

#### Oggetto della richiesta

L'interessato ha il diritto di ottenere dal titolare:

- La **conferma** dell'esistenza o meno di un trattamento di dati che lo riguardano.

- L'**accesso** alle informazioni relative al trattamento (finalità, categorie di dati, destinatari, periodo di conservazione, ecc.).
- Una **copia** dei dati personali oggetto di trattamento.

#### La richiesta di accesso ai dati (DSAR)

Le richieste di accesso, comunemente indicate con l'acronimo DSAR (Data Subject Access Request), sono soggette a specifiche regole:

- **Gratuità**: il titolare è tenuto a fornire la prima copia a titolo gratuito. Per eventuali copie ulteriori richieste dall'interessato, è possibile addebitare un contributo basato sui costi amministrativi.
- **Formato elettronico**: qualora la richiesta venga effettuata con mezzi elettronici, le informazioni devono essere fornite in un formato elettronico di uso comune (es. PDF, CSV), salvo diversa indicazione dell'interessato.
- **Tempistiche**: il riscontro deve avvenire "senza ingiustificato ritardo" e in ogni caso entro **1 mese** dal ricevimento della richiesta. Tale termine può essere prorogato di ulteriori 2 mesi in casi di particolare complessità, dandone comunicazione all'interessato.

#### Limiti e tutele

- **Diritti di terzi**: nel fornire copia dei dati (ad esempio registrazioni telefoniche o cronologia di conversazioni), il titolare deve provvedere all'oscuramento dei dati riferiti a terzi, al fine di tutelarne la riservatezza.
- **Riservatezza aziendale**: il diritto di accesso è limitato ai dati personali dell'interessato e non si estende a segreti industriali, proprietà intellettuale o codice software dell'azienda.
- *Esempio applicativo*: numerose piattaforme digitali (come i principali social network) offrono funzionalità denominate "Scarica i tuoi dati" (Download your data), che rappresentano un'implementazione automatizzata del diritto di accesso e portabilità.

### Diritto di rettifica (Art. 16)

Tale diritto è strettamente correlato al principio di **esattezza** dei dati. La presenza di dati inesatti può comportare pregiudizi concreti per l'interessato (ad esempio, il diniego di un finanziamento o una diagnosi medica errata).

#### Rettifica e integrazione

L'interessato ha facoltà di richiedere:

- La **rettifica** di dati inesatti (es. aggiornamento dell'indirizzo di residenza, correzione di errori anagrafici).
- L'**integrazione** di dati incompleti, anche mediante una dichiarazione integrativa (es. aggiunta di un recapito telefonico secondario qualora necessario).

### Diritto alla cancellazione - Diritto all'oblio (Art. 17)

L'articolo 17 del GDPR disciplina il cosiddetto "diritto all'oblio", ovvero il diritto dell'interessato di ottenere dal Titolare del trattamento la cancellazione dei dati personali che lo riguardano senza ingiustificato ritardo. È fondamentale notare che **non si tratta di un diritto assoluto**: esso deve essere bilanciato con altri diritti e obblighi previsti dalla legge.

#### Ambito di applicazione

L'interessato ha il diritto di ottenere la cancellazione dei dati qualora sussista uno dei seguenti motivi:

- **Esaurimento delle finalità**: i dati personali non sono più necessari rispetto agli scopi per i quali sono stati raccolti o trattati.
- **Revoca del consenso**: qualora il trattamento si basi esclusivamente sul consenso (es. marketing) e l'interessato lo revochi, in assenza di altro fondamento giuridico.
- **Opposizione al trattamento**: l'interessato si oppone al trattamento ai sensi dell'art. 21 e non sussiste alcun motivo legittimo prevalente per procedere al trattamento.
- **Trattamento illecito**: i dati personali sono stati trattati in violazione di legge.
- **Adempimento di un obbligo legale**: i dati devono essere cancellati per rispettare un obbligo previsto dal diritto dell'Unione o dello Stato membro.
- **Minori e servizi della società dell'informazione**: i dati sono stati raccolti relativamente all'offerta di servizi diretti a minori.

```
flowchart TD
    A[Richiesta di Cancellazione] --> B{Motivo valido?}
    B -- Sì (es. revoca consenso, fine scopo) --> C{Eccezioni applicabili?}
    B -- No --> D[Rifiuto Cancellazione]
    C -- Sì (es. obbligo legale, diritto cronaca) --> D
    C -- No --> E[Cancellazione Dati]
```

#### Eccezioni (Quando il diritto non si applica)

Il Titolare del trattamento non è obbligato a cancellare i dati nella misura in cui il trattamento sia necessario:

- Per l'esercizio del diritto alla **libertà di espressione e di informazione** (es. diritto di cronaca giornalistica).
- Per l'adempimento di un **obbligo legale** che richieda il trattamento (es. conservazione delle fatture per finalità fiscali).
- Per motivi di **interesse pubblico nel settore della sanità pubblica**.
- A fini di archiviazione nel pubblico interesse, di ricerca scientifica o storica o a fini statistici.
- Per l'accertamento, l'esercizio o la **difesa di un diritto in sede giudiziaria**.

### Diritto di limitazione del trattamento (Art. 18)

Il diritto di limitazione (art. 18) consente all'interessato di ottenere il "blocco" temporaneo del trattamento. I dati personali vengono conservati dal Titolare, ma non possono essere elaborati o utilizzati per altre finalità senza il consenso dell'interessato (salvo per la difesa di un diritto o per motivi di interesse pubblico).

#### Casistiche

La limitazione può essere richiesta quando:

- L'interessato **contesta l'esattezza** dei dati personali (la limitazione dura per il periodo necessario al Titolare per verificare l'esattezza di tali dati).
- Il trattamento è **illecito** e l'interessato si oppone alla cancellazione dei dati, chiedendo invece che ne sia limitato l'utilizzo.
- I dati sono necessari all'interessato per l'accertamento, l'esercizio o la **difesa di un diritto in sede giudiziaria**, benché il Titolare non ne abbia più bisogno ai fini del trattamento.
- L'interessato si è **opposto al trattamento** (art. 21), in attesa della verifica in merito all'eventuale prevalenza dei motivi legittimi del Titolare rispetto a quelli dell'interessato.

### Diritto alla portabilità (Art. 20)

L'articolo 20 introduce il diritto alla portabilità, finalizzato a garantire la libera circolazione dei dati e a promuovere la concorrenza tra fornitori di servizi digitali, riducendo il rischio di *lock-in* tecnologico (la dipendenza forzata da un unico fornitore).

#### Definizione e requisiti

L'interessato ha il diritto di ricevere i dati personali che lo riguardano, forniti a un Titolare, in un formato **strutturato, di uso comune e leggibile da dispositivo automatico** (es. CSV, XML, JSON), e ha il diritto di trasmettere tali dati a un altro Titolare senza impedimenti. Questo diritto si applica solo se:

- Il trattamento si basa sul **consenso** o su un **contratto**.
- Il trattamento è effettuato con **mezzi automatizzati**.

#### Differenze con il diritto di accesso

- **Diritto di Accesso (Art. 15)**: Permette di prendere visione dei dati e verificarne la correttezza. Il formato di risposta deve essere intelligibile per l'essere umano, ma non necessariamente elaborabile da una macchina (es. un documento PDF scansionato).
- **Diritto alla Portabilità (Art. 20)**: Permette il riutilizzo dei dati e il loro trasferimento. Il formato deve essere *machine-readable* per consentire l'importazione in altri sistemi software.

### Diritto di opposizione (Art. 21)

Il diritto di opposizione consente all'interessato di opporsi, in qualsiasi momento, al trattamento dei propri dati personali effettuato per specifiche finalità.

#### Tipologie di opposizione

1. **Opposizione al marketing diretto**: Qualora i dati personali siano trattati per finalità di marketing diretto (inclusa la profilazione connessa), l'interessato ha il diritto di opporsi in qualsiasi momento. In questo caso, il diritto è **assoluto**: il Titolare deve interrompere immediatamente il trattamento per tali finalità senza poter opporre alcuna eccezione.
2. **Opposizione per motivi connessi alla situazione particolare**: L'interessato può opporsi al trattamento basato sul **legittimo interesse** del Titolare o sull'esecuzione di un compito di **interesse pubblico**. In tal caso, il Titolare deve astenersi dal trattare ulteriormente i dati, a meno che non dimostri l'esistenza di motivi legittimi cogenti che prevalgono sugli interessi, sui diritti e sulle libertà dell'interessato, oppure per l'accertamento, l'esercizio o la difesa di un diritto in sede giudiziaria.

### Diritto di opposizione alle decisioni automatizzate (Art. 22)

L'articolo 22 tutela l'interessato dai rischi derivanti da decisioni prese esclusivamente da algoritmi, senza supervisione umana. L'interessato ha il diritto di **non essere sottoposto a una decisione basata unicamente sul trattamento automatizzato**, compresa la profilazione, che produca effetti giuridici che lo riguardano o che incida in modo analogo significativamente sulla sua persona.

#### Applicazione e garanzie

- **Divieto generale**: Di norma, tali processi decisionali sono vietati (es. licenziamento automatico basato su metriche di performance, rifiuto automatico di un mutuo online).
- **Eccezioni**: Il trattamento è consentito se:
  - È necessario per la conclusione o l'esecuzione di un **contratto**.
  - È autorizzato dal **diritto** dell'Unione o dello Stato membro.
  - Si basa sul **consenso esplicito** dell'interessato.

- **Garanzie obbligatorie**: Nei casi in cui il trattamento automatizzato è consentito (contratto o consenso), il Titolare deve attuare misure appropriate per tutelare i diritti dell'interessato, tra cui almeno il diritto di ottenere l'**intervento umano** da parte del Titolare, di esprimere la propria opinione e di contestare la decisione.

# 7. Figure del trattamento

Il GDPR definisce una chiara gerarchia di responsabilità per garantire che ogni trattamento sia riconducibile a un soggetto responsabile.

### Interessato (Art. 4, punto 1)

L'**Interessato** (Data Subject) è la persona fisica identificata o identificabile a cui si riferiscono i dati personali. È il soggetto a cui il GDPR mira a garantire il controllo sulle proprie informazioni personali e al quale sono riconosciuti specifici diritti (Art. 12-22).

Una persona si considera identificabile se può essere riconosciuta, direttamente o indirettamente, tramite uno o più elementi identificativi (es. nome, indirizzo, codice fiscale, indirizzo IP, cookie ID).

### Titolare del trattamento (Art. 4, 24)

Il **Titolare** (Controller) è il baricentro del sistema. È la persona fisica o giuridica che, singolarmente o insieme ad altri, determina le **finalità** (il "perché") e i **mezzi** (il "come") del trattamento.

- **Responsabilità:** il Titolare deve garantire e deve essere in grado di dimostrare (Accountability) che il trattamento è conforme al regolamento. Su di lui ricadono gli obblighi di fornire l'informativa, gestire i diritti degli interessati e notificare eventuali data breach.
- **Contitolarità (Art. 26):** si verifica quando due o più titolari determinano congiuntamente le finalità e i mezzi del trattamento. Devono stipulare un accordo interno che definisca le rispettive responsabilità.
- **Esempi pratici di Titolare:**
  - **Un'azienda:** che decide di raccogliere i dati dei propri dipendenti per gestire le buste paga e i turni di lavoro.
  - **Un libero professionista:** (es. un avvocato o un medico) che raccoglie i dati dei propri clienti/pazienti per fornire le proprie prestazioni professionali.
  - **Un'associazione sportiva:** che raccoglie i dati dei soci per gestire le iscrizioni e le gare.
  - **Un Condominio:** rappresentato dall'amministratore, è titolare del trattamento dei dati dei condòmini per la gestione delle spese e delle assemblee.
  - **Un Istituto Scolastico:** che tratta i dati degli studenti per finalità didattiche e amministrative.
  - **Contitolarità (Fan Page):** una Fan Page di Facebook. La Corte di Giustizia UE ha stabilito che l'amministratore della pagina e Facebook sono contitolari, poiché l'amministratore, definendo i parametri di targeting e ricevendo statistiche, contribuisce a determinare le finalità del trattamento dei visitatori.

### Responsabile del trattamento (Art. 4, 28)

Il **Responsabile** (Processor) è un soggetto esterno che tratta dati personali **per conto** del titolare del trattamento.

- **Il contratto di nomina (DPA):** il rapporto deve essere disciplinato da un atto giuridico vincolante. Il responsabile non può trattare i dati per scopi propri, ma deve attenersi

rigorosamente alle istruzioni del titolare.

- **Dovere di diligenza (culpa in eligendo)**: il titolare ha l'obbligo di scegliere **solo** responsabili che offrano garanzie sufficienti (affidabilità, risorse, sicurezza). Se si sceglie un fornitore inaffidabile che perde i dati, la responsabilità ricade anche sul titolare per la scelta inadeguata.
- **Sub-responsabili:** il responsabile non può ingaggiare un altro responsabile (sub-processor) senza previa autorizzazione scritta del titolare.
- **Esempi pratici di Responsabile:**
  - **Società di Software as a Service (SaaS):** un'azienda che utilizza un software gestionale in cloud (es. Salesforce, Microsoft 365). Il fornitore del software è il Responsabile.
  - **Provider di infrastruttura (IaaS):** un'azienda che utilizza **Amazon Web Services (AWS)** o Google Cloud per ospitare il proprio database clienti. L'azienda è il Titolare, AWS è il Responsabile.
  - **Consulente del Lavoro esterno:** l'azienda (Titolare) invia i dati dei dipendenti al consulente (Responsabile) affinché questi elabori materialmente i cedolini paga.
  - **Agenzia di Marketing:** che gestisce l'invio delle newsletter per conto di un negozio online utilizzando i dati forniti dal negozio stesso.
  - **Società di Smaltimento Documenti:** un'azienda che si occupa di distruggere documenti cartacei o supporti magnetici contenenti dati personali per conto di una banca o di un ufficio pubblico.
  - **Società di Videosorveglianza Esterna:** che gestisce da remoto le telecamere e la registrazione dei dati per conto di un supermercato.

## Persone autorizzate al trattamento (Art. 29)

In precedenza definiti "incaricati", sono i soggetti (dipendenti o collaboratori) che effettuano materialmente le operazioni di trattamento sotto l'autorità del titolare o del responsabile.

- **Istruzioni operative:** devono essere formati e ricevere istruzioni specifiche (es. "non lasciare il PC incustodito senza password", "non stampare dati sensibili su stampanti comuni").
  - *Esempio pratico:* l'impiegato dell'ufficio risorse umane che inserisce i dati dei nuovi assunti nel software gestionale.

## Schema riepilogativo

Di seguito uno schema riepilogativo delle figure coinvolte in materia di trattamento e protezione dei dati personali.

```
graph TD
    I[Interessato]
    T[Titolare]
    R[Responsabile]
    SR[Sub-Responsabile]
    DPO[DPO]
    G[Garante]
    A1[Aut. Titolare]
    A2[Aut. Responsabile]

    I -- Fornisce dati --> T
    I -- Reclami / segnalazioni --> G
    I -- Punto di contatto --> DPO
```

```
    T -- Nomina --> DPO
    T -- Nomina e istruzioni --> R
    T -- Istruzioni e formazione --> A1

    DPO -- Informa e sorveglia --> T
    DPO -- Cooperazione --> G

    G -- Vigilanza e provvedimenti --> T & R

    R -- Istruzioni e formazione --> A2
    R -- Autorizzazione e contratto --> SR

    subgraph Supervisione
        G
        DPO
    end
    subgraph Titolare
        T
        A1
    end
    subgraph Responsabile
        R
        A2
    end
    subgraph Sub-Responsabile
        SR
    end
```

## 8. Obblighi del titolare e del responsabile

Il GDPR segna il passaggio da un approccio basato sul semplice rispetto di regole formali a un approccio basato sulla gestione del rischio e sulla prova documentata delle scelte fatte (Accountability). Questo comporta una serie di obblighi operativi che il titolare e il responsabile devono assolvere quotidianamente.

### Informativa e trasparenza (Art. 13 e 14)

L'informativa privacy è il documento con cui il titolare del trattamento spiega all'interessato in che modo verranno utilizzati i suoi dati. Non è solo un adempimento legale, ma la base del principio di trasparenza.

#### Casi di raccolta diretta e indiretta

Esistono due situazioni diverse a seconda di come il titolare entra in possesso dei dati:

1. **Raccolta diretta (Art. 13):** il titolare raccoglie i dati direttamente dall'interessato.

- *Esempio:* un utente che compila un form di registrazione su un e-commerce o si iscrive a una newsletter.
- *Tempistica:* l'informativa deve essere fornita **al momento della raccolta**.

2. **Raccolta indiretta (Art. 14):** il titolare riceve i dati da terzi o da fonti pubbliche.

- *Esempio:* una società di recruiting che riceve il CV di un candidato da un'agenzia del lavoro, o un'azienda che acquista un database di lead per finalità di marketing.
- *Tempistica:* l'informativa deve essere fornita entro un termine ragionevole, e comunque **entro un mese** dall'ottenimento dei dati, oppure al momento della prima comunicazione con l'interessato. In questa informativa va obbligatoriamente indicata la **fonte** (origine) dei dati.

#### Requisiti di forma e linguaggio

L'informativa deve superare il vecchio modello del "muro di testo" legale.

- **Linguaggio semplice:** evitare termini come "ivi incluso", "testé menzionato" o citazioni di articoli di legge senza spiegazione. Deve essere comprensibile da un utente medio.
- **Accessibilità:** deve essere raggiungibile con un massimo di due click dalla homepage di un sito o tramite QR Code su documenti cartacei.
- **Approccio multi-livello (Layered Notice):**
  - *Livello 1 (Short notice):* un breve popup o tooltip che riassume chi è il titolare e le 2-3 finalità principali.
  - *Livello 2 (Full notice):* il documento completo con tutti i dettagli legali.
  - *Esempio informatico:* l'uso di **icone standardizzate** per indicare a colpo d'occhio se i dati vengono usati per profilazione, inviati a terzi o trasferiti all'estero.

## Data protection by design e by default (Art. 25)

Questo articolo impone ai programmatori e ai progettisti di sistemi informatici di integrare la protezione dei dati nel ciclo di vita dello sviluppo del software (SDLC).

#### Privacy by design (fin dalla progettazione)

Significa che la protezione dei dati deve essere un requisito funzionale fin dalla fase di analisi.

- *Esempio informatico:* se sto progettando un database, decido di **non usare il Codice Fiscale come chiave primaria**, ma un UUID (Universally Unique Identifier) per ridurre l'esposizione di dati identificativi nelle relazioni tra tabelle.
- *Esempio informatico:* implementare la **cifratura end-to-end** in un sistema di messaggistica prima ancora di scrivere il codice per l'interfaccia utente.

#### Privacy by default (per impostazione predefinita)

Il sistema deve essere configurato per trattare, "di fabbrica", solo i dati strettamente necessari.

- *Esempio informatico:* un'app di social network che, appena installata, imposta il profilo dell'utente come **"Privato"**. L'utente dovrà agire intenzionalmente per renderlo pubblico (Opt-in).
- *Esempio informatico:* un software che non attiva la geolocalizzazione GPS a meno che la funzione specifica non venga avviata dall'utente.

## Registro delle attività di trattamento (Art. 30)

Il registro è la "mappa" dei trattamenti di un'organizzazione. È un documento (spesso un file Excel o un database) che elenca tutti i tipi di dati trattati e come vengono gestiti.

- **Chi deve tenerlo:** formalmente le imprese con meno di 250 dipendenti sarebbero esentate, ma poiché quasi ogni azienda tratta dati dei dipendenti o dati sanitari in modo non occasionale, **il registro è di fatto obbligatorio per quasi tutti**.

## Valutazione d'impatto - DPIA (Art. 35)

La **DPIA (Data Protection Impact Assessment)** è un'analisi preventiva e documentata dei rischi. È obbligatoria quando un trattamento prevede l'uso di nuove tecnologie e può presentare un rischio elevato.

I casi tipici in cui serve una DPIA sono:

- trattamenti automatizzati con effetti giuridici o profilazione su larga scala;
- trattamento su larga scala di dati sensibili o giudiziari;
- sorveglianza sistematica su larga scala di zone accessibili al pubblico (es. sistemi di videosorveglianza urbana o riconoscimento facciale).

La DPIA deve descrivere il trattamento, valutarne la necessità e la proporzionalità e, soprattutto, elencare i rischi e le misure previste per attenuarli. Se dopo l'analisi il rischio rimane comunque elevato, il titolare ha l'obbligo di consultare preventivamente il Garante (Art. 36).

## Sicurezza del trattamento (Art. 32)

Il GDPR impone di adottare **misure adeguate al rischio**. Per gli studenti di informatica, questo si traduce in procedure tecniche specifiche:

### Procedure tecniche di sicurezza

1. **Controllo degli accessi (Access Control):** implementare il principio del *Least Privilege* (minimo privilegio). Un utente o un processo deve avere accesso solo ai dati necessari per il suo compito specifico. Uso di **MFA (Multi-Factor Authentication)** obbligatoria per gli amministratori di sistema.
2. **Protezione del dato (Data Protection):**

- **Cifratura (Encryption):** dati cifrati "at rest" (sui dischi) e "in transit" (tramite protocolli TLS 1.3).
- **Hashing:** non memorizzare mai password in chiaro, ma usare algoritmi di hashing sicuri (es. **Argon2** o **bcrypt**) con aggiunta di *salt*.

3. **Resilienza e Disaster Recovery:** implementazione di backup immutabili (per proteggersi dai ransomware) e procedure di ripristino testate periodicamente.
4. **Hardening e Patch Management:** aggiornamento costante del software e disattivazione di servizi o porte non necessari sui server.
5. **Auditing e Logging:** tracciamento degli accessi ai dati sensibili per poter ricostruire chi ha visualizzato cosa in caso di incidente (senza però loggare dati personali inutili nei file di log).

## Data breach e notifiche (Art. 33 e 34)

Un **data breach** è un incidente di sicurezza che compromette la riservatezza, l'integrità o la disponibilità dei dati.

### Tipologie di violazione

Possiamo classificare gli incidenti in tre categorie:

- **Violazione di riservatezza:** accesso non autorizzato o divulgazione accidentale (es. SQL Injection che esfiltra il database utenti).
- **Violazione di integrità:** alterazione non autorizzata dei dati (es. un malware che modifica i dati delle cartelle cliniche).
- **Violazione di disponibilità:** perdita o distruzione dei dati (es. un attacco **Ransomware** che cifra i file rendendoli inaccessibili, o un incendio nel data center).

### Esempi strutturati di Data Breach

- **Errore umano:** un impiegato invia per errore una mail contenente l'elenco dei debitori morosi a tutti i clienti della banca invece che all'ufficio recupero crediti.
- **Configurazione errata (Misconfiguration):** un database NoSQL (es. MongoDB) lasciato esposto su internet senza password di amministratore.
- **Furto fisico:** lo smarrimento o il furto di un computer aziendale con il disco rigido non cifrato.

**Procedura di risposta**

1. **Notifica al Garante (entro 72 ore):** obbligatoria se c'è un rischio per i diritti delle persone.
2. **Comunicazione all'interessato:** obbligatoria se il rischio è **elevato** (es. furto di credenziali bancarie o dati sanitari). Non è necessaria se i dati erano cifrati e la chiave è rimasta sicura.

# 9. Autorità di controllo e sanzioni

Il GDPR non si limita a stabilire regole teoriche, ma istituisce un sistema di vigilanza e repressione per garantire che tali regole siano effettivamente rispettate. Questo sistema si basa sulle autorità di controllo nazionali, che agiscono in modo indipendente ma coordinato a livello europeo, e su un apparato sanzionatorio estremamente severo, concepito per essere un deterrente efficace anche per le grandi multinazionali.

## Data Protection Officer (DPO) (Art. 37-39)

Il DPO costituisce una delle novità più rilevanti introdotte dal GDPR. Non si tratta di un semplice dipendente, ma di un professionista con un ruolo ibrido: deve possedere competenze giuridiche, informatiche e di analisi dei processi aziendali.

### Chi è e qual è il suo ruolo

Il DPO è il "garante interno" all'organizzazione. Il suo compito principale è facilitare l'osservanza del GDPR, al fine di tutelare i dati delle persone fisiche.

Egli funge da **punto di contatto** tra tre parti:

- Il **Titolare/Responsabile** (l'azienda/ente).
- Gli **Interessati** (i cittadini di cui si trattano i dati).
- L'**Autorità di Controllo** (il Garante).

### Quando è obbligatorio nominarlo (Art. 37)

La nomina del DPO non è obbligatoria per tutte le organizzazioni, ma lo è in tre casi specifici:

1. **Pubblica Amministrazione ed Enti Pubblici**:

- Tutte le PA devono nominarne uno (scuole, comuni, ospedali, ministeri).
- *Esempio*: Ogni istituto scolastico dispone di un DPO (spesso un consulente esterno) che supporta il Dirigente Scolastico nella gestione della privacy di studenti e personale.

2. **Monitoraggio regolare e sistematico su larga scala**:

- Riguarda aziende il cui core business consiste nel tracciamento del comportamento delle persone.
- *Esempio*: Una compagnia assicurativa che utilizza scatole nere (black box) per monitorare lo stile di guida dei clienti; provider di servizi internet (ISP) che analizzano il traffico dati; applicazioni di fitness che tracciano costantemente la posizione e i parametri sanitari.

3. **Trattamento su larga scala di dati sensibili o giudiziari**:

- Aziende che trattano categorie particolari di dati come attività principale.
- *Esempio*: Una clinica privata, un laboratorio di analisi mediche, un sindacato nazionale.

- *Controesempio*: Un singolo medico o avvocato che opera come libero professionista non è tenuto alla nomina, in quanto il trattamento non avviene su "larga scala".

**Requisiti e posizione organizzativa (Art. 38)**

Il GDPR stabilisce regole rigorose per garantire che il DPO possa operare efficacemente:

- **Competenze**: Deve possedere una conoscenza specialistica della normativa e delle prassi in materia di protezione dati. Solitamente è un giurista con competenze informatiche o viceversa.
- **Indipendenza**: Il DPO **non deve ricevere istruzioni** sull'esecuzione dei propri compiti. Il Titolare non può limitare il suo ambito di controllo o ignorare le segnalazioni di non conformità.
- **Assenza di conflitto di interessi**: Questo aspetto è critico. Il DPO non può rivestire ruoli che comportino la definizione delle finalità e dei mezzi del trattamento.
  - *Chi NON può ricoprire il ruolo di DPO*: L'Amministratore Delegato, il Direttore Marketing (interessato all'uso dei dati per vendite), il Direttore IT (responsabile delle misure di sicurezza che il DPO deve controllare), il Responsabile HR.
  - *Esempio Reale*: Nel 2022 il Garante ha sanzionato un'azienda in cui il DPO era contemporaneamente a capo dell'Audit Interno e membro del consiglio di amministrazione, configurando un evidente conflitto di interessi. Le funzioni di controllo e gestione non possono coincidere.
- **Risorse**: L'organizzazione deve fornire le risorse necessarie (budget, personale, accesso ai dati) per l'espletamento dei compiti.

**I compiti del DPO (Art. 39)**

1. **Informare e consigliare**: Fornire consulenza al Titolare e ai dipendenti in merito agli obblighi normativi.
2. **Sorvegliare**: Verificare il rispetto delle procedure, condurre audit interni e controllare la documentazione.
3. **Pareri sulla DPIA**: Fornire il proprio parere sulla Valutazione d'Impatto sulla Protezione dei Dati.
4. **Cooperare con il Garante**: Agire come punto di riferimento per le ispezioni o le richieste di informazioni.
5. **Punto di contatto per gli interessati**: Gestire le richieste degli utenti (es. esercizio dei diritti) qualora i canali ordinari non forniscano riscontro.

## L'autorità di controllo: il Garante per la protezione dei dati personali

L'autorità di controllo è l'organo pubblico indipendente incaricato di sorvegliare l'applicazione del regolamento (Art. 51). In Italia, questa funzione è svolta dal **Garante per la protezione dei dati personali** (spesso chiamato semplicemente "Garante Privacy").

L'indipendenza (Art. 52) è l'elemento cardine di questa istituzione. Per poter vigilare correttamente, anche sull'operato dello Stato e delle altre pubbliche amministrazioni, l'autorità deve essere libera da qualsiasi influenza esterna, sia essa politica, finanziaria o operativa. I membri del Garante non possono ricevere istruzioni da nessuno e devono disporre di risorse umane, tecniche e finanziarie proprie e sufficienti.

In Italia, il Garante è un organo collegiale composto da quattro membri, eletti dal Parlamento (due dalla Camera e due dal Senato), scelti tra persone che offrono garanzie di indipendenza e che possiedono una comprovata esperienza nel settore della protezione dei dati personali. Il mandato dura sette anni e non è rinnovabile.

## Compiti e poteri del Garante

Il regolamento attribuisce alle autorità di controllo una vasta gamma di funzioni, che possono essere suddivise in compiti di monitoraggio, sensibilizzazione e intervento diretto.

I compiti principali (Art. 57) includono:

- Sorvegliare l'applicazione del regolamento e assicurarne il rispetto.
- Promuovere la consapevolezza del pubblico riguardo ai rischi e ai diritti legati al trattamento, con particolare attenzione alle attività destinate ai minori.
- Fornire consulenza al Parlamento e al Governo sulle misure legislative legate alla protezione dei dati.
- Gestire i reclami proposti dagli interessati e condurre le relative indagini.
- Cooperare con le altre autorità di controllo degli Stati membri dell'Unione Europea.

Per assolvere a questi compiti, l'Art. 58 conferisce al Garante tre tipologie di poteri:

1. **Poteri di indagine:** permettono all'autorità di verificare se un trattamento è conforme. Il Garante può ingiungere al titolare di fornire informazioni, condurre indagini sotto forma di audit (revisioni), ottenere l'accesso a tutti i dati personali e a tutte le informazioni necessarie, nonché ottenere l'accesso a tutti i locali del titolare o del responsabile, compresi gli strumenti e i mezzi di trattamento.
2. **Poteri correttivi:** sono gli strumenti di intervento in caso di violazione. Includono:

- Rivolgere avvertimenti (se un trattamento previsto rischia di violare il GDPR).
- Infliggere ammonimenti (se la violazione è già avvenuta).
- Ingiungere al titolare di soddisfare le richieste dell'interessato (es. esercizio del diritto di accesso).
- Imporre una limitazione provvisoria o definitiva al trattamento, incluso il divieto totale di trattare i dati (blocco).
- Ordinare la rettifica o la cancellazione dei dati.
- Infliggere sanzioni amministrative pecuniarie.

3. **Poteri autorizzativi e consultivi:** riguardano il rilascio di pareri al titolare o l'autorizzazione di specifici trattamenti previsti dalla legge.

## Il meccanismo di cooperazione e coerenza

Poiché i dati digitali non hanno confini, il GDPR introduce un sistema per evitare che ogni autorità nazionale agisca in modo isolato.

Il meccanismo principale è lo **"sportello unico" (one-stop-shop)** (Art. 56). Se un'azienda (come Google o Meta) opera in più Stati membri, il suo interlocutore principale sarà l'autorità di controllo dello Stato in cui ha lo stabilimento principale, detta **Lead Supervisory Authority (autorità capofila)**. Questo semplifica la vita alle imprese, che non devono gestire 27 interlocutori diversi, ma garantisce comunque che le autorità degli altri Stati coinvolti possano partecipare alla decisione.

A livello centrale opera il **Comitato europeo per la protezione dei dati (EDPB - European Data Protection Board)**, un organismo dell'Unione Europea che riunisce i rappresentanti di tutte le autorità nazionali e il Garante europeo della protezione dei dati (EDPS). Il compito dell'EDPB è assicurare l'applicazione coerente del GDPR in tutta l'Unione, emettendo linee guida e risolvendo eventuali controversie tra le autorità nazionali quando non riescono a raggiungere un accordo su un caso transfrontaliero.

```
graph TD
  A[Interessato / Cittadino] -- Reclamo --> B[Garante Nazionale]
  B -- Collaborazione --> C[Altre Autorità UE]
  B -- Partecipazione --> D[EDPB - Comitato Europeo]
  D -- Linee Guida e Decisioni Vincolanti --> B
  E[Titolare Transfrontaliero] -- Interfaccia Unica --> F[Autorità Capofila]
  F -- Coordinamento --> C
```

## Tutela dell'interessato: reclami e ricorsi

L'ordinamento offre all'interessato due strade principali per far valere i propri diritti (Art. 77, 78, 79):

- **Il reclamo al Garante:** è una procedura amministrativa gratuita che permette al cittadino di segnalare una violazione. Il Garante è obbligato a esaminare il reclamo, informare l'interessato dello stato delle indagini ed emettere una decisione. È la strada più semplice e rapida per bloccare un trattamento illecito.
  - È possibile compilare un modulo online sul sito del Garante.
  - Oggetto del reclamo può essere: ricezione di telefonate indesiderate (marketing aggressivo), mancata cancellazione di dati, pubblicazione non autorizzata di immagini online, videosorveglianza abusiva sul posto di lavoro.
- **Il ricorso giurisdizionale:** l'interessato può decidere di rivolgersi direttamente all'autorità giudiziaria ordinaria (il Tribunale) contro il titolare o il responsabile del trattamento. Inoltre, è possibile fare ricorso al giudice contro una decisione del Garante stesso, se si ritiene che tale decisione sia errata.

Queste due strade sono alternative ma possono anche essere parallele, con la differenza fondamentale che solo il giudice può condannare il titolare al risarcimento dei danni economici.

## Il sistema sanzionatorio e il diritto al risarcimento

Il sistema delle sanzioni è uno degli aspetti più discussi del GDPR per via della sua severità.

**Diritto al risarcimento (Art. 82):** chiunque subisca un danno materiale (es. perdita finanziaria) o immateriale (es. danno alla reputazione, stress psicologico) causato da una violazione del regolamento ha il diritto di ottenere il risarcimento del danno dal titolare o dal responsabile. Un punto fondamentale è che il titolare è esonerato dalla responsabilità solo se dimostra che l'evento dannoso non gli è in alcun modo imputabile (**inversione dell'onere della prova**).

**Sanzioni amministrative pecuniarie (Art. 83):** le multe non sono fisse, ma vengono calcolate in base a criteri specifici: natura e gravità della violazione, durata, carattere doloso (volontario) o colposo (negligenza), misure adottate per attenuare il danno e grado di cooperazione con il Garante.

Il regolamento prevede due scaglioni massimi di sanzione:

1. **Fino a 10.000.000 € o al 2% del fatturato mondiale annuo dell'esercizio precedente** (si applica il valore più alto): per violazioni degli obblighi del titolare o responsabile (es. mancata nomina del DPO, mancata tenuta del registro dei trattamenti, omessa DPIA).
2. **Fino a 20.000.000 € o al 4% del fatturato mondiale annuo dell'esercizio precedente** (si applica il valore più alto): per violazioni dei principi fondamentali (es. liceità, correttezza, trasparenza), dei diritti degli interessati o per l'inosservanza di un ordine del Garante.

**Sanzioni penali:** il GDPR lascia agli Stati membri la libertà di prevedere ulteriori sanzioni, incluse quelle penali. In Italia, il **Codice Privacy** (D.Lgs. 196/2003, modificato dal D.Lgs. 101/2018) prevede il

carcere per reati specifici, come il trattamento illecito di dati su larga scala fatto per trarne profitto o per arrecare danno, la comunicazione e diffusione illecita di dati o la falsità nelle dichiarazioni fornite al Garante durante un'ispezione.

# 10. Casi di studio dal mondo reale

L'analisi dei casi reali è fondamentale per comprendere come i principi teorici del GDPR si traducano in sanzioni, danni reputazionali e impatti operativi per le organizzazioni.

## Synlab Italia: l'attacco ransomware del gruppo Black Basta (2024)

L'attacco subito da Synlab Italia nell'aprile 2024 rappresenta uno dei data breach più gravi mai avvenuti nel settore sanitario italiano, sia per la quantità di dati coinvolti che per la loro estrema delicatezza. Synlab è un colosso della diagnostica medica che gestisce centinaia di laboratori e punti prelievo in tutta Italia.

### Dinamica dell'incidente e "Double Extortion"

Il 18 aprile 2024, i sistemi informatici di Synlab sono stati colpiti da un ransomware sferrato dal gruppo cybercriminale **Black Basta**. Gli attaccanti hanno utilizzato una tecnica nota come **double extortion** (doppia estorsione):

1. **Cifratura dei dati:** i file sui server aziendali sono stati resi illeggibili, bloccando ogni attività operativa.
2. **Esfiltrazione dei dati:** prima di cifrare i sistemi, gli hacker hanno sottratto circa **1,5 Terabyte** di documenti riservati, minacciando di pubblicarli se non fosse stato pagato un riscatto milionario in criptovalute.

### Tipologia di dati coinvolti (Art. 9)

La gravità del caso risiede nella natura dei dati esposti sul Dark Web dopo che l'azienda ha rifiutato di pagare il riscatto. Sono state pubblicate migliaia di cartelle cliniche contenenti:

- **Categorie particolari di dati:** referti medici di ogni tipo (esami del sangue, biopsie, test del DNA), terapie farmacologiche, storie cliniche complete.
- **Dati personali identificativi:** scansioni di carte d'identità, codici fiscali e tessere sanitarie dei pazienti.
- **Dati aziendali:** contratti, documenti amministrativi e comunicazioni interne.

### Analisi della Triade RID

L'attacco ha causato un fallimento totale dei tre pilastri della sicurezza informatica:

- **Disponibilità (Availability):** i servizi di prelievo e refertazione sono rimasti paralizzati per giorni. Molti pazienti non hanno potuto ritirare esami urgenti, mettendo potenzialmente a rischio la loro salute.
- **Integrità (Integrity):** durante la fase di ripristino dai backup, è stato necessario verificare che i dati non fossero stati alterati o corrotti dagli attaccanti.
- **Riservatezza (Confidentiality):** la pubblicazione sul Dark Web ha reso i dati sanitari accessibili a chiunque sapesse come cercarli, violando permanentemente la privacy dei pazienti.

### Aspetti del GDPR infranti

In base all'analisi preliminare dell'incidente, sono emerse gravi criticità relative a diversi articoli del regolamento:

1. **Art. 32 (Sicurezza del trattamento):** la capacità di un ransomware di propagarsi così velocemente in tutta l'infrastruttura nazionale suggerisce una carenza nelle misure tecniche di segmentazione della rete. La mancanza di sistemi di monitoraggio efficaci (DLP - Data Loss Prevention) ha permesso l'esfiltrazione di una mole enorme di dati senza che venisse bloccata in tempo reale.
2. **Art. 5, par. 1, lett. f) (Integrità e riservatezza):** l'azienda non è stata in grado di garantire la protezione dei dati da trattamenti non autorizzati, venendo meno al principio cardine del GDPR.
3. **Art. 25 (Data Protection by Design):** l'infrastruttura non si è dimostrata resiliente. Un sistema progettato con criteri di "sicurezza fin dalla progettazione" avrebbe dovuto prevedere meccanismi di isolamento dei guasti per evitare il blocco totale del servizio a livello nazionale.
4. **Art. 33 e 34 (Notifica e comunicazione):** sebbene Synlab abbia informato il Garante e gli interessati, la comunicazione iniziale è stata criticata per essere stata inizialmente troppo rassicurante e poco specifica sulla reale entità del furto di dati sanitari.

#### Il dilemma etico e legale del riscatto

Synlab ha pubblicamente dichiarato di non aver pagato il riscatto, seguendo le raccomandazioni delle autorità di polizia e del Garante. Pagare un riscatto, infatti:

- Finanzia il crimine organizzato.
- Non garantisce che i dati non vengano comunque venduti o pubblicati in futuro.
- Rende l'azienda un bersaglio per attacchi successivi.

Tuttavia, questa scelta ha portato alla ritorsione degli hacker e alla diffusione dei dati dei pazienti, sollevando un dibattito sulla responsabilità del titolare nel proteggere la dignità dell'interessato a ogni costo.

```
sequenceDiagram
    participant H as Hacker (Black Basta)
    participant S as Server Synlab
    participant D as Dark Web
    participant P as Pazienti

    H->>S: Accesso abusivo e esfiltrazione (1.5TB)
    H->>S: Cifratura file (Ransomware)
    S-->>P: Blocco servizi (Disponibilità KO)
    H->>S: Richiesta riscatto
    Note over S: Rifiuto pagamento (Accountability)
    H->>D: Pubblicazione dati (Riservatezza KO)
    D->>P: Rischio furto identità e discriminazione
```

### ho.mobile: il furto dei codici ICCID e la minaccia del SIM Swapping (2021)

Il caso ho.mobile (operatore virtuale di Vodafone) è scoppiato tra la fine del 2020 e l'inizio del 2021, quando un database contenente i dati di circa **2,5 milioni di clienti** è stato messo in vendita su un noto forum di hacker. Questo incidente è particolarmente significativo per la tipologia di dati tecnici sottratti e per il rischio sistemico che ha generato.

#### I dati sottratti: oltre l'anagrafica

Oltre ai comuni dati personali (nome, cognome, codice fiscale, indirizzo), gli attaccanti hanno esfiltrato un dato tecnico critico: l'**ICCID** (International Circuit Card Identifier). L'ICCID è il numero seriale

univoco di 19 cifre stampato sulla SIM. In ambito di telefonia, questo codice funge da "chiave" per le operazioni di portabilità (passaggio ad altro operatore) e per la sostituzione della SIM.

#### La minaccia: il SIM Swapping

Il possesso congiunto di dati anagrafici e codice ICCID espone l'utente al rischio di **SIM Swapping**.

1. **L'attacco:** l'hacker contatta l'operatore telefonico (o si reca in un punto vendita) fingendo di essere la vittima. Sostenendo di aver smarrito la SIM e fornendo i dati anagrafici e l'ICCID rubati, ottiene l'attivazione di una nuova SIM sul proprio dispositivo, disattivando quella legittima della vittima.
2. **L'obiettivo:** una volta ottenuto il controllo del numero di telefono, l'attaccante può intercettare gli SMS di **autenticazione a due fattori (2FA)**. Questo permette di violare conti correnti bancari, profili social e account email che utilizzano il numero di cellulare come sistema di sicurezza.

#### La risposta dell'azienda e il GDPR

Sotto il profilo del GDPR, il caso ho.mobile ha evidenziato l'importanza della gestione tempestiva degli incidenti (Accountability):

- **Art. 34 (Comunicazione all'interessato):** ho.mobile ha informato massivamente i clienti tramite SMS, spiegando l'accaduto e i rischi potenziali.
- **Soluzione "Software-Defined":** per mitigare il rischio di SIM Swapping senza costringere 2,5 milioni di persone a recarsi fisicamente in negozio per cambiare SIM, ho.mobile ha adottato una misura innovativa. Ha **rigenerato da remoto l'ICCID** di tutte le SIM coinvolte. Il codice stampato sulla plastica è diventato nullo, e un nuovo codice virtuale è stato inviato via SMS agli utenti per le future operazioni.

#### Analisi della Triade RID

- **Riservatezza (Confidentiality):** gravemente compromessa. L'esposizione dell'ICCID ha reso pubbliche le "chiavi di accesso" alle linee telefoniche.
- **Integrità (Integrity):** l'attacco ha messo a rischio l'integrità dell'identità digitale degli utenti (rischio di impersonificazione).
- **Disponibilità (Availability):** non è stata colpita direttamente l'infrastruttura di rete, ma la disponibilità della linea per l'utente legittimo sarebbe venuta meno in caso di successo dell'attacco di SIM Swapping.

```
graph LR
    A[Database ho.mobile] -- Furto --> B(Dati Anagrafici + ICCID)
    B -- Vendita --> C[Cybercriminali]
    C -- Impersonificazione --> D{Operatore Telefonico}
    D -- Nuova SIM --> E[Hacker controlla SMS 2FA]
    E -- Accesso --> F[Home Banking / Social]
```

### TIM (Telecom Italia): Telemarketing selvaggio e fallimento dei processi di controllo (2020)

Il caso TIM rappresenta una delle pietre miliari dell'applicazione del GDPR in Italia. Nel gennaio 2020, il Garante per la protezione dei dati personali ha inflitto alla compagnia telefonica una sanzione di **27,8 milioni di euro**. Questo provvedimento non è nato da un singolo errore tecnico (come un bug o un attacco hacker), ma da una gestione strutturalmente carente dei processi di marketing e del controllo sui partner esterni (call center), evidenziando un fallimento del principio di **Accountability**.

### Il contesto dell'istruttoria

L'indagine è stata avviata a seguito di un'ondata senza precedenti di segnalazioni: tra il 2017 e il 2019, centinaia di cittadini hanno lamentato la ricezione continua di chiamate promozionali indesiderate. Il Garante ha accertato che le violazioni non erano episodi isolati, ma facevano parte di un sistema di "telemarketing aggressivo" che ha coinvolto milioni di persone.

Durante le ispezioni, sono emersi numeri impressionanti:

- Migliaia di chiamate effettuate verso utenti che non avevano mai fornito il consenso.
- Contatti ripetuti verso persone iscritte al Registro Pubblico delle Opposizioni.
- Un caso limite in cui un singolo interessato è stato contattato ben **155 volte in un solo mese** (una media di 5 telefonate al giorno).

### Le violazioni operative nel dettaglio

#### Il caos delle Black List e il disallineamento tecnico

Uno dei problemi tecnici più gravi ha riguardato la gestione delle cosiddette **Black List** (liste di esclusione). Quando un utente dichiara durante una telefonata di non voler più essere contattato ("Opt-out"), il titolare ha l'obbligo di inserire quel numero in una lista nera per evitare futuri disturbi.

In TIM, è emerso un **disallineamento sistematico** tra i database della casa madre e quelli dei call center partner (i Responsabili del trattamento). Le informazioni non fluivano correttamente: un utente che negava il consenso a un operatore continuava a essere chiamato da un altro call center perché i sistemi informatici non erano sincronizzati in tempo reale o con frequenza adeguata. Questo dimostra una grave carenza di **Privacy by Design**: il sistema non era stato progettato per garantire l'efficacia del diritto di opposizione.

#### Dark Patterns e "Tim Party"

Il Garante ha analizzato anche il programma di fidelizzazione "Tim Party". In questo contesto, l'azienda utilizzava dei **Dark Patterns** (modelli manipolatori): per poter accedere ai premi e agli sconti del programma, agli utenti veniva richiesto obbligatoriamente di prestare il consenso per finalità di marketing e profilazione. Questo rende il consenso **nullo**, poiché l'Art. 7 del GDPR stabilisce che il consenso deve essere **libero**: se l'erogazione di un servizio (il programma premi) è subordinata a un consenso non necessario per il servizio stesso, quel consenso è considerato "estorto" e quindi invalido.

#### Conservazione eccessiva dei dati (Data Hoarding)

TIM conservava nei propri database i dati di potenziali clienti (i cosiddetti *prospect*) per periodi lunghissimi, ben oltre i termini necessari per le finalità di marketing o quelli stabiliti dalla legge. Molti di questi dati venivano poi utilizzati per campagne promozionali "fuori lista", ovvero contatti effettuati senza poter dimostrare l'origine del dato o la presenza di un consenso valido.

### Aspetti del GDPR infranti (Analisi Tecnica)

Il provvedimento del Garante elenca una serie di violazioni che toccano quasi tutti i pilastri del regolamento:

- **Art. 5 (Principi applicabili al trattamento):**
  - **Liceità, correttezza e trasparenza:** il trattamento era illecito (senza consenso) e scorretto (molestia telefonica).
  - **Limitazione della conservazione:** i dati venivano mantenuti nei sistemi troppo a lungo.
  - **Integrità e riservatezza:** i flussi di dati verso i call center non erano sicuri e controllati.

- **Art. 6 e 7 (Base giuridica e Consenso):** TIM non è stata in grado di dimostrare la presenza di consensi validi per milioni di contatti. Il consenso raccolto tramite "Tim Party" è stato dichiarato invalido perché non libero.
- **Art. 21 (Diritto di opposizione):** l'azienda ha sistematicamente ignorato la volontà degli utenti di non ricevere più pubblicità, a causa dei già citati problemi tecnici di sincronizzazione delle liste.
- **Art. 24 e 25 (Responsabilità e Privacy by Design):** TIM, in qualità di Titolare, ha fallito nel monitorare l'operato dei suoi Responsabili (call center). Inoltre, non ha implementato misure tecniche e organizzative adeguate per protectgere i dati "fin dalla progettazione".
- **Art. 31 (Cooperazione con l'autorità):** durante l'ispezione, TIM ha fornito informazioni parziali o non tempestive, ostacolando in parte l'attività del Garante.

#### Lo schema del fallimento del controllo

Il seguente diagramma illustra come il disallineamento tecnico abbia causato la violazione dei diritti degli interessati.

```
sequenceDiagram
    participant I as Interessato (Utente)
    participant C1 as Call Center A (Responsabile)
    participant T as Database TIM (Titolare)
    participant C2 as Call Center B (Responsabile)

    C1->>I: Chiamata promozionale
    I->>C1: "Non voglio più essere chiamato" (Opposizione)
    C1->>C1: Inserimento in Black List locale
    Note over C1,T: MANCATA SINCRONIZZAZIONE (Errore tecnico)
    T->>C2: Invio lista contatti (incluso l'utente interessato)
    C2->>I: Seconda chiamata indesiderata
    I-->>I: Violazione Art. 21 GDPR
```

#### Sanzioni e misure correttive

Oltre alla sanzione pecuniaria di **27.802.946 euro**, il Garante ha imposto a TIM una serie di obblighi di "fare" (misure correttive) estremamente rigorosi:

1. **Divieto assoluto** di utilizzare i dati degli utenti presenti nelle liste di esclusione per finalità di marketing.
2. **Obbligo di bonifica:** TIM ha dovuto ripulire i propri database, eliminando tutti i dati raccolti senza un consenso documentabile o conservati oltre i termini.
3. **Revisione di Tim Party:** l'azienda è stata obbligata a separare la partecipazione al programma dal consenso marketing, rendendo quest'ultimo opzionale.
4. **Audit sui partner:** l'obbligo di implementare un sistema di controllo ferreo sui call center esterni, con verifiche periodiche sulla qualità dei dati e sul rispetto delle opposizioni degli utenti.

### Enel Energia: La multa record e il "Sottobosco" dei database illeciti (2024)

Nell'aprile 2024, il Garante per la protezione dei dati personali ha inflitto a Enel Energia una sanzione di oltre **79 milioni di euro** (79.107.101 €), la più alta mai emessa dall'autorità italiana. Questo caso è emblematico perché non riguarda solo telefonate moleste, ma l'esistenza di un vero e proprio mercato nero dei dati personali, definito dal Garante come il "sottobosco" del telemarketing.

### Il contesto dell'indagine

L'istruttoria è nata da una vasta operazione della Guardia di Finanza che ha portato al sequestro di database illeciti presso quattro società partner di Enel. È emerso che queste società raccoglievano dati di cittadini senza alcun consenso, spesso acquistandoli da fonti non ufficiali o rubandoli da altri operatori, per poi utilizzarli per vendere contratti di fornitura energetica.

L'aspetto più grave è che Enel Energia, pur essendo il Titolare del trattamento, ha permesso che migliaia di contratti acquisiti in questo modo entrassero nei propri sistemi informatici senza verifiche adeguate sulla provenienza dei dati.

### Il fenomeno del "Sottobosco" e le agenzie ombra

Il cuore della violazione risiede nella gestione della rete di vendita. Molte grandi aziende si affidano ad agenzie di vendita ufficiali, le quali però a loro volta sub-appaltano il lavoro ad agenzie più piccole (spesso non autorizzate dal Titolare). Queste "agenzie ombra":

- Utilizzano liste di numeri di telefono illegali.
- Effettuano chiamate senza rispettare il Registro delle Opposizioni.
- Caricano i contratti finalizzati sui portali aziendali utilizzando credenziali di accesso ottenute in modo poco trasparente.

### Le falle tecniche e organizzative

L'indagine ha rivelato che i sistemi informatici di Enel Energia presentavano delle gravi vulnerabilità, definite dal Garante come "porte aperte" (front doors):

- **Accessi non controllati:** agenzie esterne non facenti parte della rete ufficiale riuscivano a inserire nuovi contratti nei database aziendali.
- **Mancanza di validazione:** il sistema non verificava se il cliente inserito avesse effettivamente fornito un consenso valido prima dell'attivazione della fornitura.
- **Incapacità di monitoraggio:** l'azienda non disponeva di strumenti tecnici per tracciare l'origine esatta di ogni singolo dato inserito dai partner commerciali.

### Aspetti del GDPR infranti (Analisi Tecnica)

Le violazioni contestate riflettono un fallimento totale nella protezione dei dati:

- **Art. 5 (Integrità e Riservatezza):** Enel non ha protetto i propri database da inserimenti abusivi di terze parti, venendo meno all'obbligo di garantire che i dati siano trattati in modo sicuro.
- **Art. 24 (Accountability):** l'azienda non è stata in grado di dimostrare di aver adottato misure organizzative sufficienti per controllare la propria filiera di vendita. Il Titolare è responsabile dell'operato dei suoi Responsabili (e sub-responsabili).
- **Art. 25 (Privacy by Design):** i software di gestione dei contratti erano progettati per favorire la velocità di acquisizione a scapito della verifica della legalità dei dati (mancanza di controlli preventivi sul consenso).
- **Art. 32 (Sicurezza del trattamento):** la presenza di falle che permettevano a soggetti non autorizzati di interagire con i sistemi aziendali costituisce una violazione degli obblighi minimi di sicurezza tecnica.

### Lo schema del telemarketing illecito

Il diagramma seguente mostra come i dati provenienti dal "mercato nero" venivano iniettati nei sistemi ufficiali.

```
graph TD
    A[Database Illeciti / Mercato Nero] -- Vendita dati --> B(Agenzia Ombra non
autorizzata)
    B -- Chiamate moleste --> C[Interessato / Cittadino]
    C -- Firma contratto ignaro --> B
    B -- Caricamento abusivo --> D{Sistemi IT Enel}
    D -- Attivazione servizio --> E[Guadagno illecito provvigioni]

    subgraph "Vulnerabilità (Porte Aperte)"
    D
    end
```

#### L'importanza della sanzione

La cifra record di 79 milioni è stata calcolata tenendo conto di diverse aggravanti:

- La **vastità del fenomeno** (migliaia di contratti illeciti).
- La **durata della violazione** (protrattasi per anni nonostante i precedenti avvertimenti).
- L'**elevato fatturato** dell'azienda (secondo l'Art. 83, la multa può arrivare al 4% del fatturato mondiale).

Questo caso ha stabilito un principio fondamentale: le aziende non possono più "chiudere un occhio" sull'operato della loro rete di vendita. Il Titolare deve garantire la legalità di ogni singolo dato che entra nei propri sistemi, indipendentemente da quanti passaggi di mano abbia subito.

### ChatGPT (OpenAI): Il primo blocco di un'IA generativa (2023-2024)

Il caso ChatGPT, scoppiato nella primavera del 2023, ha rappresentato un momento di svolta globale nel rapporto tra intelligenza artificiale e protezione dei dati. Per la prima volta, un'autorità di controllo nazionale (il Garante italiano) ha imposto un blocco a una piattaforma di IA generativa di portata mondiale, sollevando interrogativi fondamentali sulla compatibilità tra i modelli di linguaggio (LLM) e il GDPR.

#### Cronologia dei fatti: il braccio di ferro tra Garante e OpenAI

L'andamento cronologico degli eventi è fondamentale per comprendere come si sia passati da una crisi totale a una parziale armonizzazione del servizio con le norme europee:

- **20 marzo 2023 (Il Data Breach):** un malfunzionamento tecnico permette ad alcuni utenti di visualizzare i titoli delle chat di altri utenti e, in alcuni casi, informazioni di pagamento (nome, cognome, indirizzo e-mail, ultime quattro cifre della carta di credito) degli abbonati a ChatGPT Plus.
- **31 marzo 2023 (Il Blocco Cautelare):** il Garante per la protezione dei dati personali dispone, con effetto immediato, la **limitazione provvisoria del trattamento** dei dati degli utenti italiani. OpenAI, in risposta, decide di rendere ChatGPT inaccessibile dall'Italia.
- **11 aprile 2023 (Le Prescrizioni):** il Garante pubblica un elenco di misure che OpenAI deve adottare per poter riaprire il servizio. Queste includono maggiore trasparenza, strumenti per l'esercizio dei diritti e sistemi di verifica dell'età.
- **28 aprile 2023 (Il Ripristino):** OpenAI implementa le prime modifiche richieste (nuova informativa, form di opposizione, controllo età all'accesso) e il servizio torna raggiungibile in Italia.
- **Gennaio 2024 (L'Atto di Contestazione):** a conclusione dell'istruttoria, il Garante notifica a OpenAI l'atto di contestazione per ulteriori violazioni della normativa privacy, dando il via alla

fase finale del procedimento sanzionatorio.

### Gli aspetti del GDPR infranti

È fondamentale sottolineare che il Garante non ha contestato la tecnologia dell'intelligenza artificiale in sé, ma il modo in cui OpenAI **tratta i dati personali** degli esseri umani per far funzionare tale tecnologia.

### Assenza di base giuridica per l'addestramento (Art. 6)

OpenAI raccoglie enormi quantità di dati da internet (*web scraping*) per addestrare i propri modelli. Il Garante ha contestato l'assenza di una base giuridica idonea per questo trattamento massivo. Inizialmente, OpenAI sembrava fare affidamento sull'**esecuzione di un contratto**, ma il Garante ha chiarito che l'addestramento dell'algoritmo non è necessario per fornire il servizio di chat all'utente, ma serve all'azienda per migliorare il proprio prodotto. OpenAI ha successivamente virato verso il **legittimo interesse**, che richiede però di permettere agli utenti di opporsi facilmente.

### Carenza di informativa (Art. 13 e 14)

Al momento del lancio, ChatGPT non forniva un'informativa chiara agli utenti su come i loro dati venissero utilizzati per l'addestramento. Ancora più grave era la mancanza di informativa per i "non utenti" (persone i cui dati sono stati raccolti online dal crawler di OpenAI), che non avevano alcun modo di sapere che le loro informazioni personali stavano venendo elaborate da un'IA.

### Violazione del principio di esattezza (Art. 5, par. 1, lett. d)

Le cosiddette "allucinazioni" dell'IA rappresentano un problema giuridico grave. ChatGPT può generare testi che attribuiscono a persone reali fatti mai accaduti o dichiarazioni mai rese. Poiché i dati elaborati dall'IA sono dati personali, il fatto che siano inesatti viola il principio di **esattezza**, e OpenAI non forniva strumenti per rettificare queste informazioni (essendo tecnicamente difficile correggere un dato interno a un modello già addestrato).

### Protezione dei minori (Art. 8)

Nonostante il servizio fosse teoricamente rivolto a maggiori di 13 anni, non esisteva alcun filtro efficace. L'assenza di un sistema di **age verification** esponeva i minori a risposte potenzialmente inappropriate rispetto al loro grado di sviluppo e autoconsapevolezza, violando la tutela rafforzata che il GDPR riserva loro.

### Difficoltà nell'esercizio dei diritti (Art. 21)

Inizialmente, non era previsto alcun meccanismo semplice per chiedere l'esclusione dei propri dati personali dal set di addestramento. Il diritto di opposizione deve essere garantito, specialmente se la base giuridica utilizzata è il legittimo interesse.

### Trattamento dati vs Intelligenza Artificiale

Bisogna fare attenzione a non confondere la "magia" dell'algoritmo con il "trattamento dati". La questione ChatGPT è puramente legata al ciclo di vita del dato:

1. **Input:** dati raccolti per l'addestramento (violazione base giuridica e informativa).
2. **Processo:** elaborazione dei dati degli utenti durante l'uso (violazione sicurezza/data breach).
3. **Output:** informazioni errate fornite dall'IA (violazione esattezza).

```
graph TD
    A[Web Scraping / Dati Utenti] -->|Input| B(Modello IA - Training)
    B -->|Output| C[Risposte della Chat]
```

```
    subgraph "Criticità GDPR"
    D[Base Giuridica Assente] -.-> A
    E[Informativa Carente] -.-> A
    F[Dati Inesatti / Allucinazioni] -.-> C
    G[Mancanza Filtri Minori] -.-> B
    end
```

#### Le misure correttive adottate

Per poter rientrare nel mercato italiano, OpenAI ha dovuto implementare diverse soluzioni tecniche e organizzative:

- **Trasparenza:** pubblicazione di un'informativa dedicata ai soli utenti europei e di un'altra per i non utenti.
- **Controllo Utente:** inserimento di un'opzione nelle impostazioni per disattivare l'uso delle chat ai fini dell'addestramento e un form online per chiedere la rimozione di informazioni personali dai risultati della ricerca dell'IA.
- **Verifica Età:** introduzione di un blocco all'ingresso che richiede la conferma della data di nascita o del consenso dei genitori per i minori.

Il caso ChatGPT dimostra che nessuna tecnologia, per quanto innovativa o "intelligente", può operare al di sopra delle leggi che proteggono la dignità e la riservatezza delle persone fisiche nell'Unione Europea.

## Risorse

### Approfondimenti generali

- Testo del Regolamento UE 2016/679 (GDPR)
- Wikipedia: Regolamento generale sulla protezione dei dati
- La Legge per Tutti: GDPR, principi fondamentali
- PrivacyLab: Titolare, Responsabile e Incaricato

### Privacy Guides

- Perché la privacy è importante
- Threat Modeling
- Minacce comuni
- Falsi miti sulla privacy

### Dark Patterns

- Garante Privacy: Temi - Internet e nuove tecnologie - Dark pattern
- Wikipedia: Dark pattern
- Hall of Shame: Design Collection
- Caso Studio: Ryanair e i dark pattern
- Caso Studio: Amazon e i dark pattern

### Casi di studio

#### Synlab

- Federprivacy: Attacco hacker a Synlab Italia
- Cybersecurity360: Possibile violazione dati pazienti Synlab
- GHC: Comunicazioni attacco Synlab

- Sky TG24: Dati Synlab nel Dark Web

**ho.mobile**

- Cybersecurity360: ho.mobile conferma furto dati
- FAQ Data Breach ho.mobile

**TIM**

- Provvedimento Garante Privacy contro TIM (2020)

**Enel**

- Provvedimento Garante Privacy contro Enel Energia (2024)
- Altalex: Multa record Enel Energia

**ChatGPT**

- Il Post: Istruttoria Garante su ChatGPT
- Il Post: ChatGPT sospeso in Italia
- Il Post: Cosa chiede il Garante a OpenAI
- Il Post: ChatGPT torna raggiungibile
- Il Post: Multa del Garante a OpenAI